Capítulo

02

Código de buenas prácticas

Objetivos

Conocer la norma NTC-ISO/IEC 27002:2007 y seleccionar, relacionar y combinar sus controles.

Conceptos

Estructura y secciones de la norma NTC-ISO/IEC 27002:2007 y sus objetivos.

2.1 Estructura de la norma

La norma NTC-ISO/IEC 27002fue preparada para servir como una guía práctica para el desarrollo y la aplicación de los procedimientos y controles de seguridad de la información en una organización.

Ejercicio de nivelación - fundamentos de la seguridad de la información

» ¿Qué entiende usted por código buenas de prácticas?

Está estructurada para proporcionar un código de buenas prácticas para la gestión de la seguridad, la norma está organizada en capítulos de 0 a 15. En los capítulos 0-4 se presentan los temas de introducción (0), el objetivo de la norma (1), los términos y las definiciones adoptadas por la norma (2), la estructura de la norma (3) y el análisis / evaluación y tratamiento de riesgos (4), y son considerados como la sección introductoria.

Desde el capítulo 5, la norma llama a cada capítulo como sección. Por lo tanto, hay once secciones específicas que ofrecen los códigos de práctica de la gestión de la seguridad.

Para cada sección, existe al menos una categoría importante de la seguridad. Las once secciones forman un total de 39 categorías principales de seguridad. En la sección 3 de la norma son presentadas las secciones y la cantidad de categorías por cada sección. Cada categoría presenta un objetivo de control y uno o más controles que deben aplicarse con el fin de alcanzar el objetivo de control.

Hay 133 controles y ellos son los elementos que definen lo que la norma 27002 considera importante para un proceso de seguridad de la información. Los controles identificados por números (xx.xx.xx) son estructurados a través de:

- **Control:** descripción y definición de control;
- **Directrices para la implementación:** información auxiliar en la implementación del control;
- **Información adicional:** informaciones complementarias.

Todo el trabajo de este capítulo será desarrollado con el manejo y la lectura de los temas presentados en la norma NTC-ISO/IEC 27002.



Figura 3. Secuencia estructural de la norma

En el sentido horario, se observa la secuencia estructural de la norma, destacando las once secciones de controles de seguridad de la información (secciones 5-15).

Más información se puede encontrar en la norma ISO27002:2007

2.2 Sección 4: análisis/evaluación y tratamiento de los riesgos

Figura 4. Sección 4: análisis/ evaluación y tratamiento de riesgos

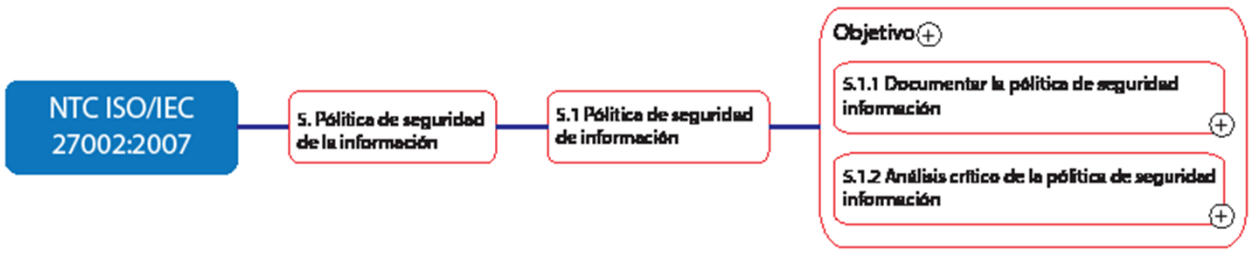
La sección 4 (análisis/evaluación y tratamiento de riesgos) es una sección introductoria que presenta objetivamente la importancia del análisis de riesgos para la organización, y las indicaciones generales de la forma en que debe hacerse.



2.3 Sección 5: política de seguridad

Figura 5. Sección 5.1: política de seguridad de la información

La sección 5 de la norma se refiere a la política de seguridad de la información. El objetivo de la categoría de control es proporcionar orientación y apoyo de gestión para la seguridad de la información, mediante el establecimiento de una política clara y objetiva, alineada con los objetivos de negocio de la organización. La sección 5 muestra la forma en que debe ser generado y actualizado el documento de la política.



Esta sección se compone de una categoría principal de seguridad (5.1: política de seguridad de la información) y dos controles (5.1.1 y 5.1.2).

El control 5.1.1 (documento de la política de seguridad de información) muestra, en las "Directrices para la implementación", lo que conviene que el documento de política contenga y la importancia de que sea comunicado a todos.

El control de 5.1.2 (análisis crítico de la política de seguridad de la información) presenta como corresponde que se realice el análisis crítico por parte de la dirección de la organización.

Ejercicio de refuerzo - sección 5: política de seguridad

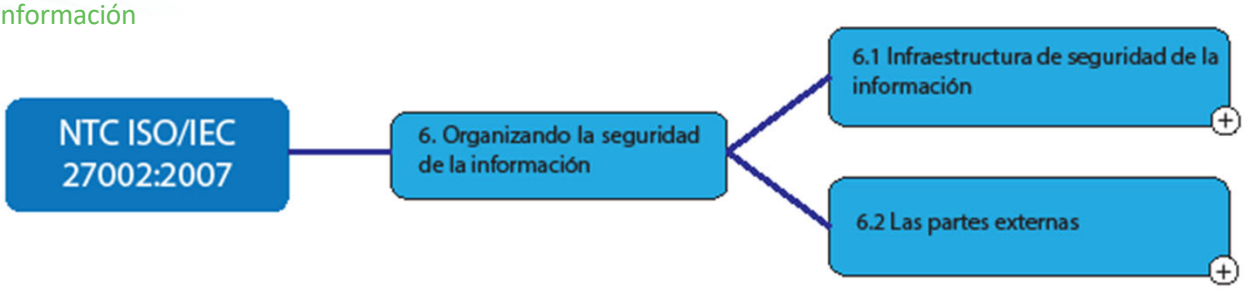
Utilizando la norma, explique:

- El objetivo de la categoría de control 5.1
- La letra b de las directrices para la implementación del control 5.1.1

2.4 Sección 6: organizando la seguridad de la información

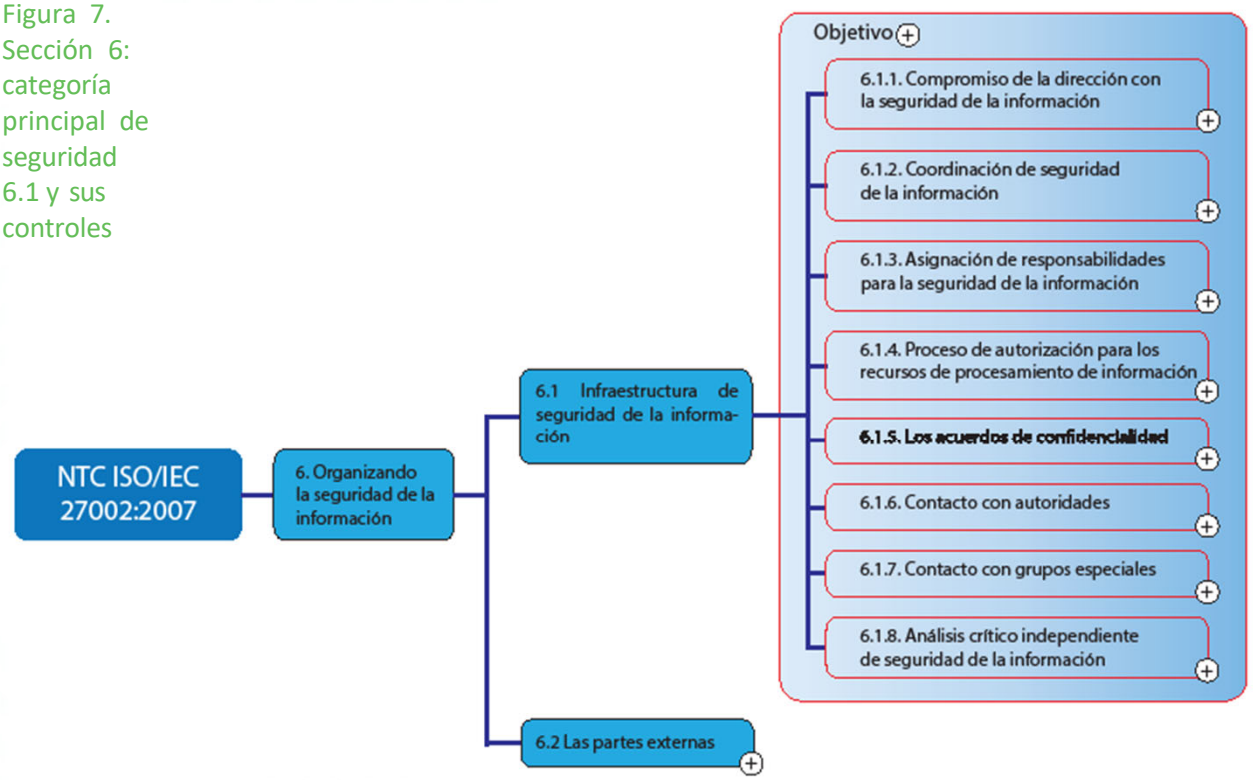
La sección 6 (organizando la seguridad de la información) tiene como objetivo presentar controles para gestionar la seguridad de la información dentro de la organización y también los controles para mantener la seguridad de los recursos de procesamiento de la información, cuando están disponibles para las partes externas. Como partes externas se entiende a todo aquel que no es parte efectiva de la estructura de la organización. Así, son ejemplos de partes externas los vendedores, proveedores, agencias gubernamentales, contratistas, proveedores de servicios temporales y los clientes, entre otros.

Figura 6.
Sección 6: organizando la seguridad de la información



En la sección 6 encontraremos los controles que deben aplicarse a la estructura funcional de la seguridad de la información. La sección 6 tiene dos categorías principales de seguridad: 6.1 (infraestructura de seguridad de la información) y 6.2 (las partes externas).

Figura 7.
Sección 6: categoría principal de seguridad 6.1 y sus controles



La categoría 6.1 (infraestructura de seguridad de la información) cuenta con ocho controles que se deben implementar. Estos controles, como puede verse en la norma, tratan de la estructura de la seguridad, sus procesos de autorización, confidencialidad, y los contactos con otros grupos.

Observe que el control 6.1.8 trata de nuevo el análisis crítico de la seguridad de la información. La seguridad de la información es parte de un proceso y debe ser analizada periódicamente, revisada y corregida para estar siempre al día con los requisitos de seguridad de la información.

Se recomendamos una lectura rápida de la categoría 6.1 de la norma ISO27002:2007.

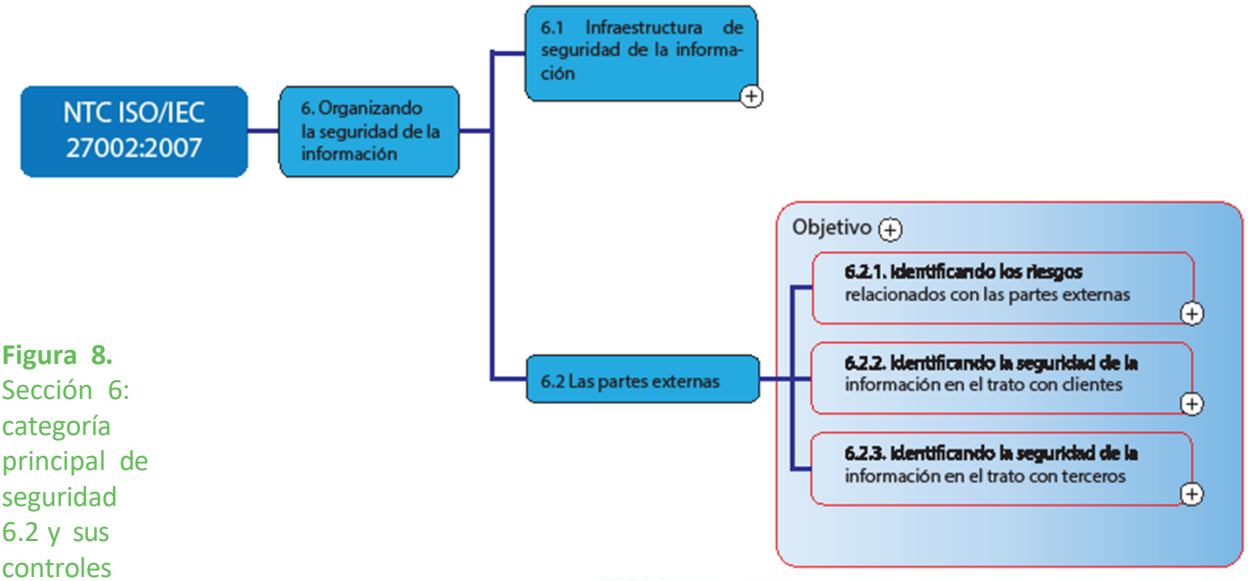


Figura 8. Sección 6: categoría principal de seguridad 6.2 y sus controles

La categoría 6.2 (partes externas) se refiere a los controles necesarios para la relación entre la organización y las partes externas que, en algún momento y por alguna razón del negocio, necesitan tener acceso a los recursos informáticos de la organización. Es una buena práctica identificar cada una de las partes externas que existen en la relación de negocios de la organización.

Tenga en cuenta los detalles de las directrices de implementación, que relaciona lo esencial a ser cumplido en la seguridad de la información.

Ejercicio de refuerzo - sección 6: organizando la seguridad de la información

Utilizando la norma, explique los controles

- 6.1.3
- 6.1.5
- 6.1.7

2.5 Sección 7: gestión de activos

En la sección 7 (gestión de activos) se presentan dos categorías principales de seguridad de la información:

- 7.1 (Responsabilidad de los activos): representa los controles que se aplican a la protección de los activos de la organización;
- 7.2 (Clasificación de la información): controles para la clasificación de la información, dándoles un nivel de seguridad adecuado.

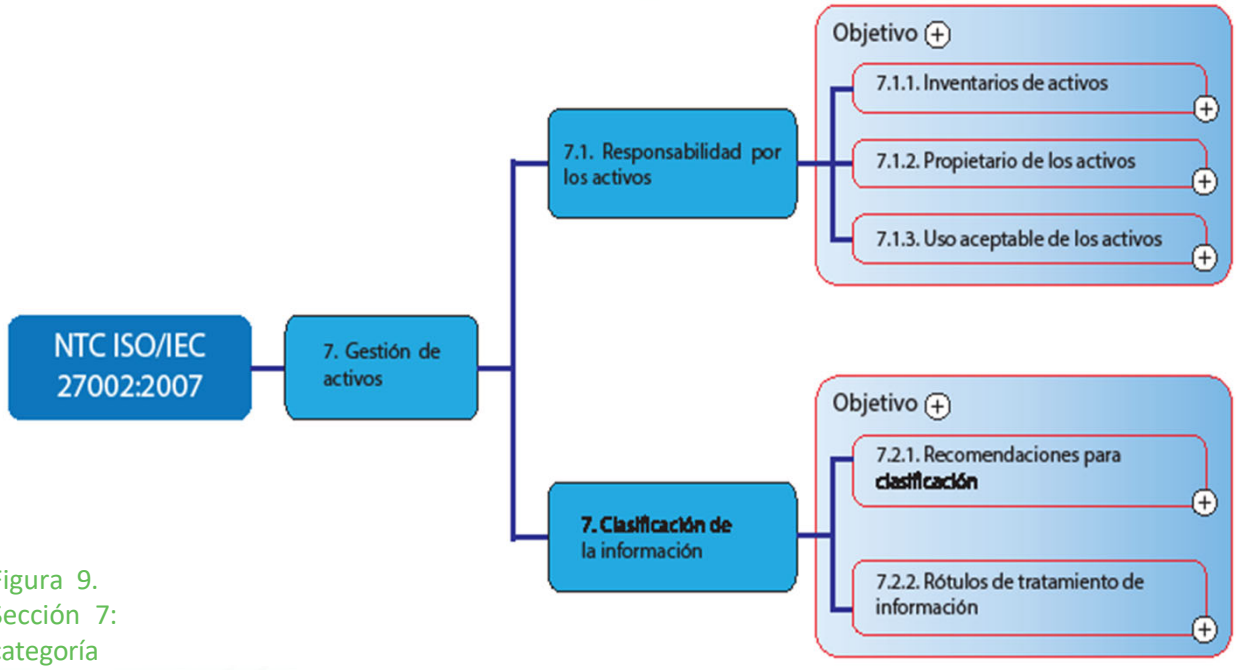


Figura 9. Sección 7: categoría principal de seguridad 7.1 y 7.2 con sus controles

La categoría 7.1 (Responsabilidad de los activos) tiene como objetivo alcanzar y mantener la protección adecuada de los activos de la organización, presentando los controles que se deben aplicar para el tratamiento de la seguridad de la información de los activos.

El control 7.1.1 de la norma, en "información adicional", describe algunos tipos de activos. La categoría 7.2 presenta los controles para el tratamiento de la seguridad de la información que deben ser aplicados.

Ejercicio de refuerzo - sección 7: gestión de activos

Utilizando la norma, explique los controles

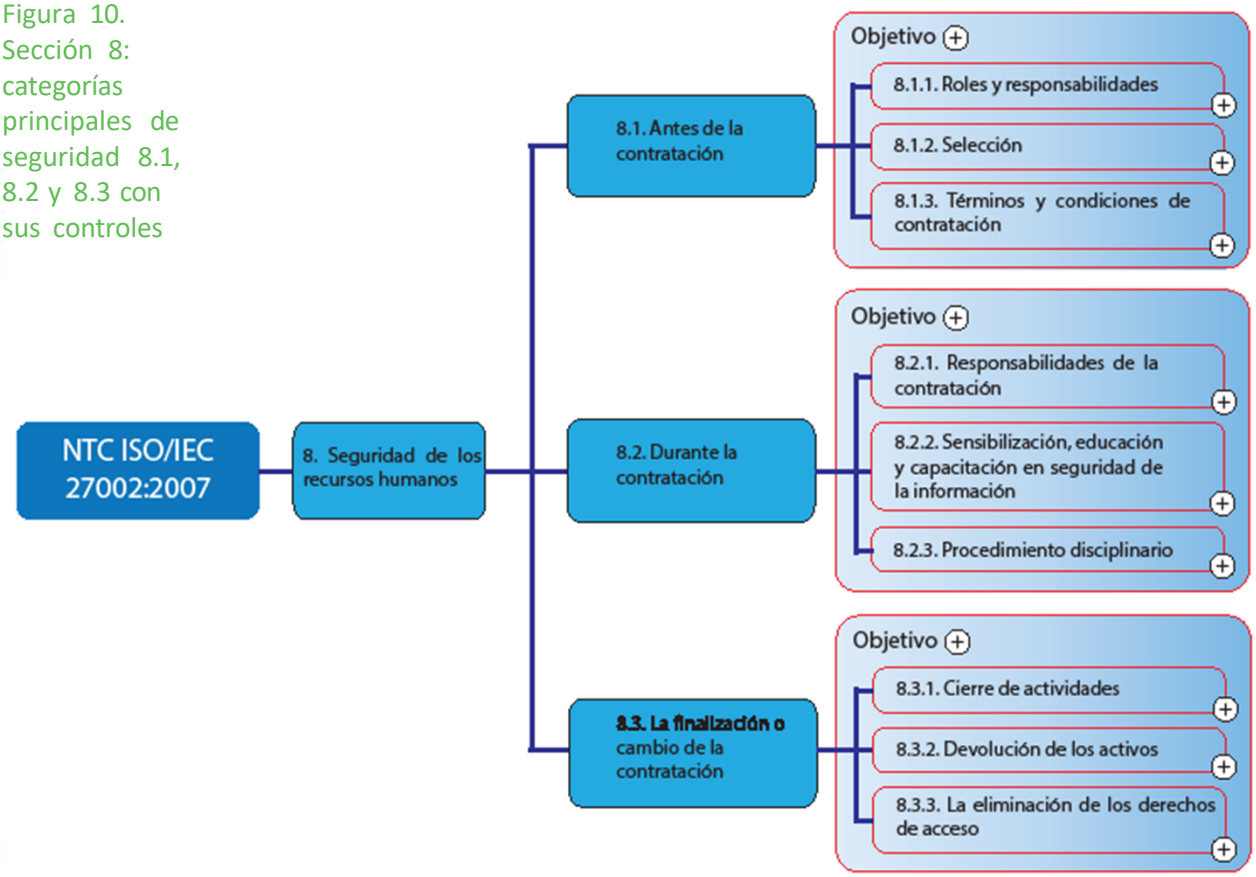
- 7.1.1
- 7.1.2
- 7.2.1

2.6 Sección 8: seguridad de los recursos humanos.

La sección 8 (seguridad de los recursos humanos) se ocupa de los controles de seguridad de la información durante el ciclo de vida de la prestación de servicio de profesionales en la organización. Estos controles están dispuestos por la norma en tres categorías:

- 8.1. Antes de la contratación;
- 8.2. Durante la contratación;
- 8.3. La finalización o cambio de la contratación.

Figura 10. Sección 8: categorías principales de seguridad 8.1, 8.2 y 8.3 con sus controles



Los controles en cada categoría se organizan dentro de las necesidades mínimas de seguridad que deben observarse en cada uno de ellos.

- Categoría 8.1 (controles responsabilidades): proceso de selección y condiciones de los contratos de recursos humanos;
- Categoría 8.2 (controles durante la prestación de los servicios propiamente dichos): en esta categoría están los controles de responsabilidades, la capacitación de los recursos humanos en seguridad de la información y los procedimientos disciplinarios, si se produce una violación de la seguridad de la información;
- Categoría 8.3 (controles específicos para el cierre o cambio de la contratación: cambio del área, de cargo, ascenso, etc.): en esta categoría se destacan los controles de devolución de los activos y la retirada de derechos de acceso.

Ejercicio de refuerzo - sección 8: seguridad en recursos humanos

Utilizando la norma, explique los controles

- 8.1.1
- 8.2.2
- 8.3.3

2.7 Sección 9: seguridad física y del entorno

Teniendo como objetivo del tratamiento de la seguridad física y del ambiente, la sección 9 (seguridad física y del ambiente) presenta dos categorías principales de seguridad de la información:

- 9.1. Áreas seguras;
- 9.2. Seguridad de los equipos.

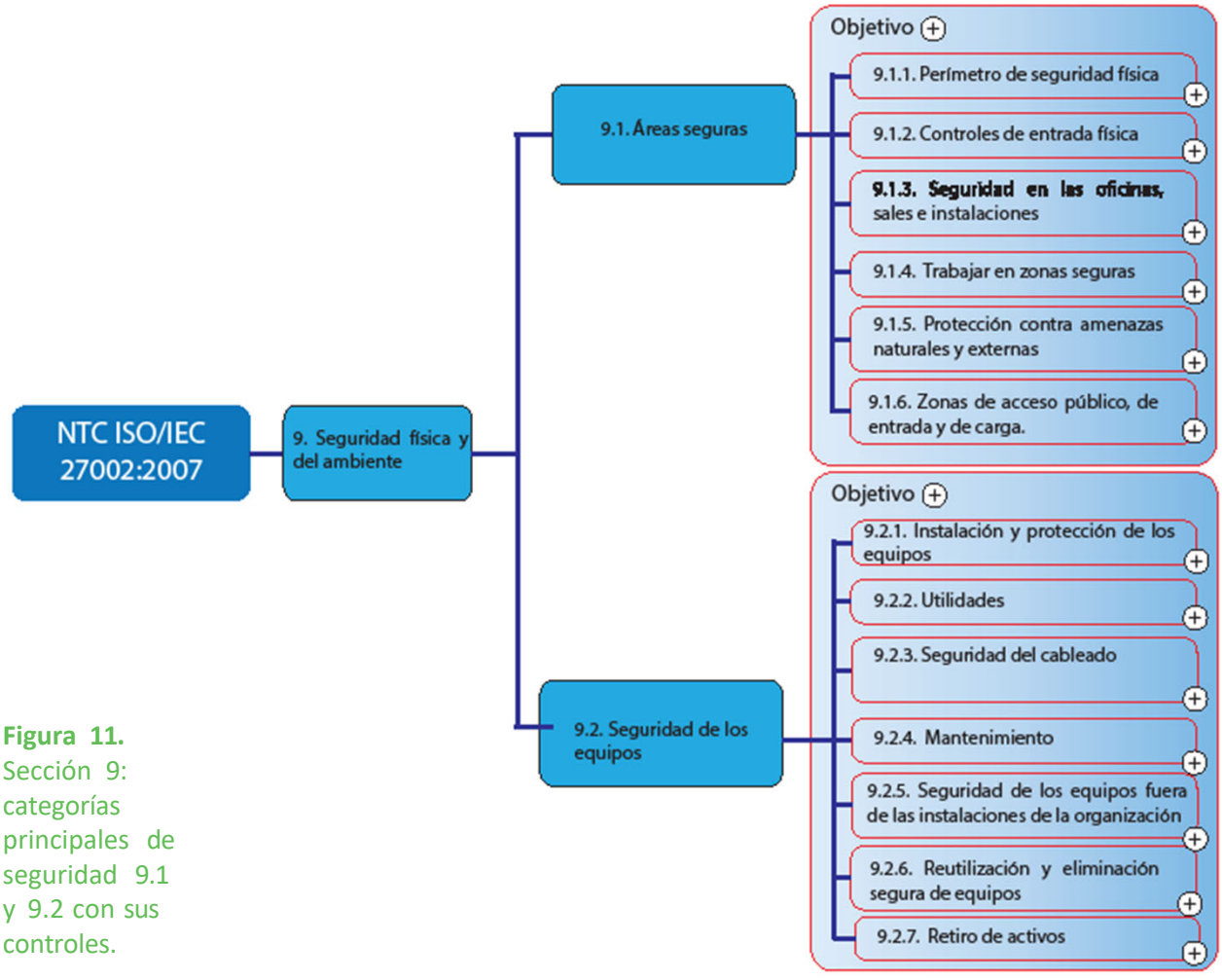


Figura 11. Sección 9: categorías principales de seguridad 9.1 y 9.2 con sus controles.

Los controles de seguridad de la categoría 9.1 (áreas seguras) se refieren específicamente a las necesidades de seguridad de acceso físico a las instalaciones. Presenta controles de seguridad para el perímetro físico, controles de entrada a las áreas internas y externas, zonas seguras, áreas de acceso público y de entrega de materiales.

En la categoría 9.2 (seguridad de equipos) están los controles de seguridad que se refieren a la protección física de los activos y su funcionamiento sin interrupciones. Es en esta categoría donde se encuentran los controles para la instalación de equipos, suministro de energía, aire acondicionado, mantenimiento de activos, la reutilización y la venta/eliminación de los activos.

Ejercicio de refuerzo - sección 9: seguridad física y del entorno

Utilizando la norma, explique los controles

- 9.1.2
- 9.1.4
- 9.2.5

2.8 Sección 10: gestión de operaciones y comunicaciones

La sección 10 (gestión de las operaciones y comunicaciones) es la sección más grande de la norma, se ocupa de las operaciones de los servicios tecnológicos de la organización. Esta sección tiene diez categorías principales de seguridad de la información, y cada uno de ellas cuenta con controles que deben ser aplicados en el día a día de las operaciones y las comunicaciones de la organización. Es la sección que muestra los controles de seguridad relacionados con la mayoría de las vulnerabilidades vinculadas a los aspectos operativos cotidianos en el área de las Tecnologías de la Información y las Comunicaciones, TICs.

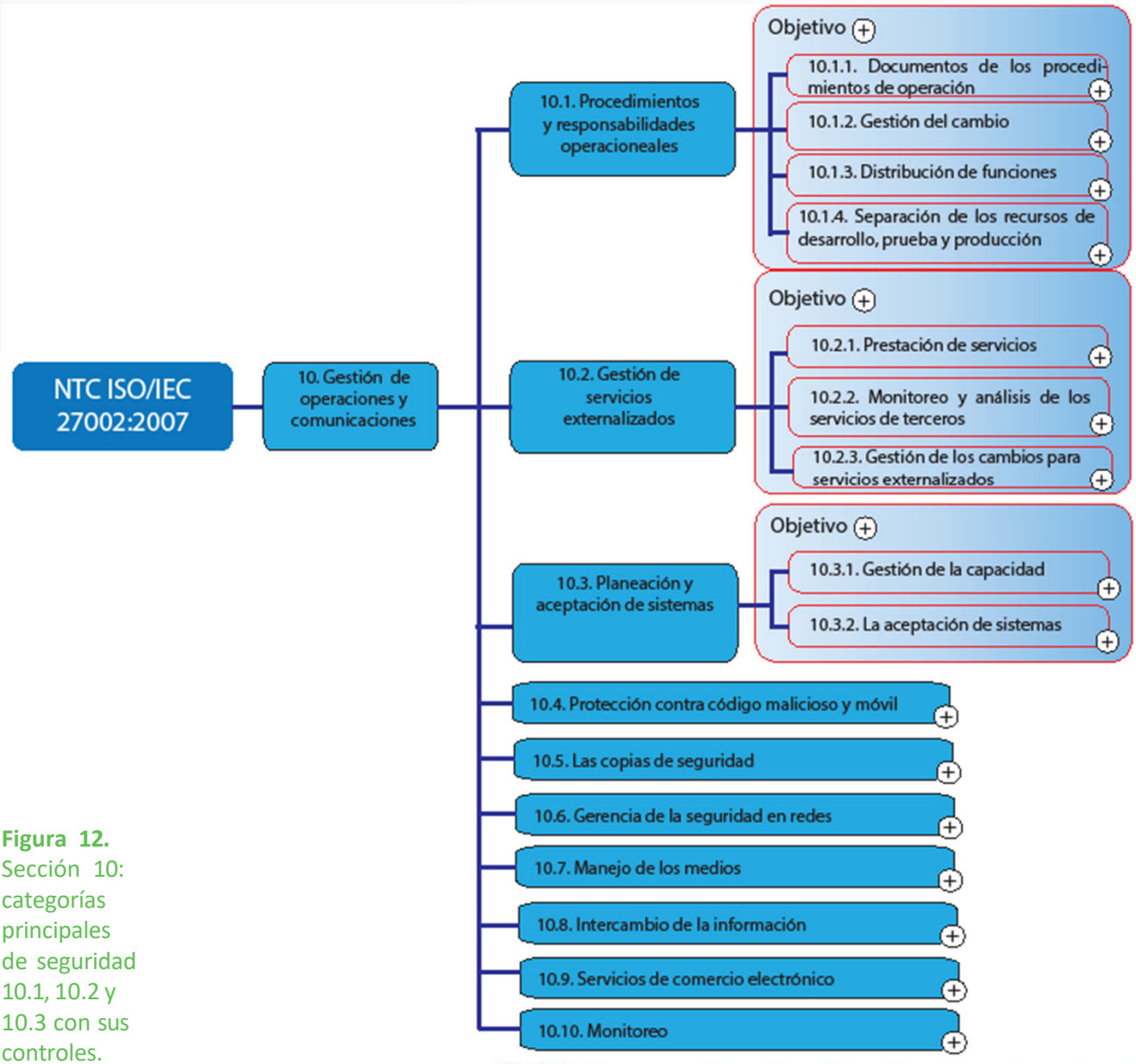


Figura 12. Sección 10: categorías principales de seguridad 10.1, 10.2 y 10.3 con sus controles.

En la categoría 10.1 (procedimientos y responsabilidades operacionales) se muestran los controles que tienen por objeto garantizar el funcionamiento seguro y correcto de los recursos informáticos. En él se describen los controles:

- 10.1.1 (documentos de los procedimientos de operación): se deben aplicar para documentar los procedimientos;
- 10.1.2 (gestión del cambio): define el modo en que se deben controlar las modificaciones y alteraciones;
- 10.1.3 (distribución de funciones): reducción de las oportunidades de uso indebido;

» 10.1.4 (separación de recursos de desarrollo, prueba y producción): describe cómo se deben separar estos ambientes para reducir el riesgo de acceso o modificación no autorizada.

La categoría 10.2 (gestión de servicios externalizados) tiene como objetivo mantener el nivel adecuado de seguridad y de la entrega de servicios de conformidad con los acuerdos. Esta categoría incluye las siguientes medidas de control:

» 10.2.1 (entrega de servicios): se refiere a la garantía de que los controles de seguridad acordados con terceros se cumplan en la realidad;
» 10.2.2 (monitoreo y análisis de los servicios de terceros): aborda la necesidad de seguimiento y análisis crítico que debe hacerse periódicamente;
» 10.2.3 (gestión del cambio para los servicios externalizados): se refiere a la necesidad de gestionar estos servicios de acuerdo al estado crítico de los sistemas y procesos.

En la categoría 10.3 (planeación y aceptación de los sistemas) el objetivo es reducir al mínimo el riesgo de fallas en los sistemas, con la presentación de los dos únicos controles:

» 10.3.1 (gestión de capacidad): se refiere al monitoreo y la sincronización de los recursos con las proyecciones de la capacidad futura para asegurar el rendimiento requerido;
» 10.3.2 (aceptación de sistemas): se refiere a la conveniencia de la realización de pruebas de aceptación de los nuevos sistemas y actualizaciones.

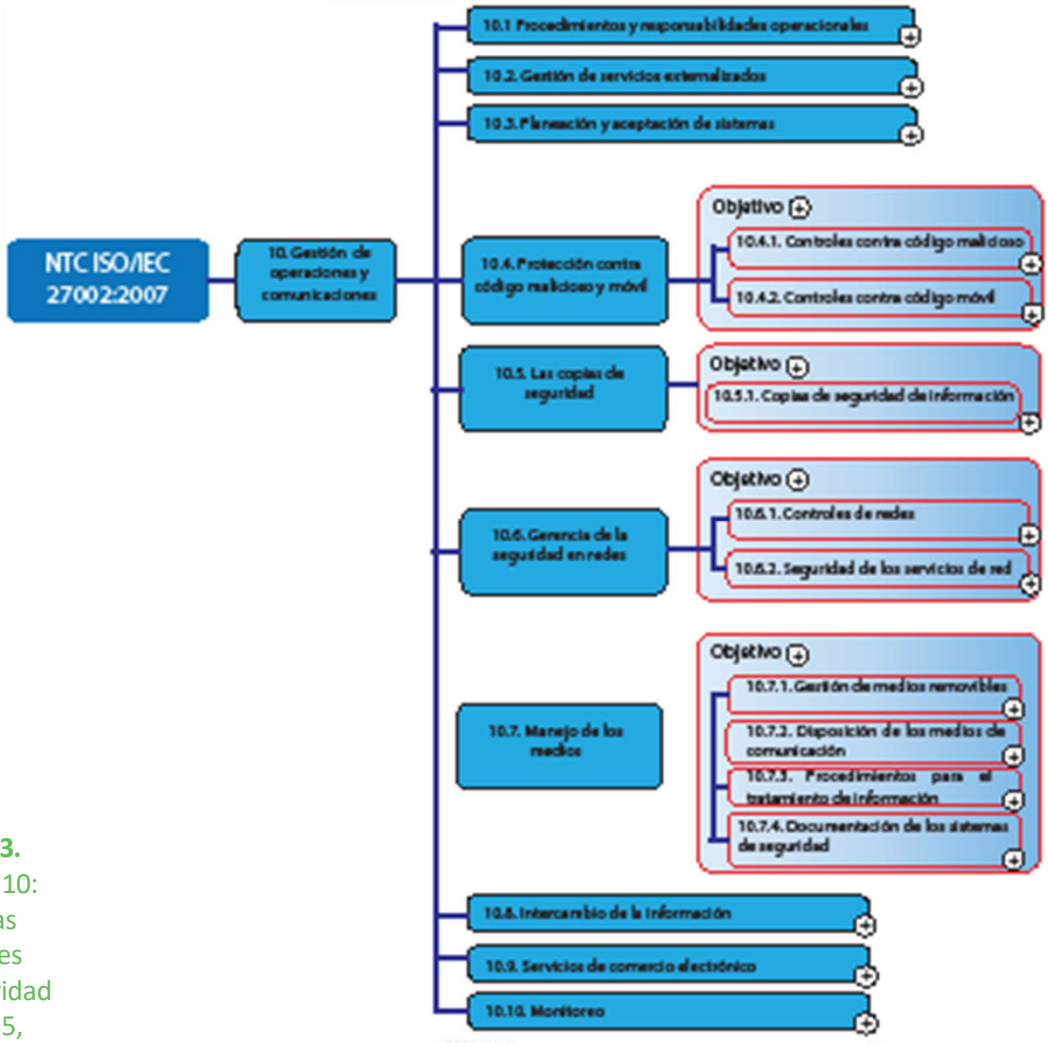


Figura 13. Sección 10: categorías principales de seguridad 10.4, 10.5, 10.6 y 10.7 con sus controles.

La categoría 10.4 (protección contra códigos maliciosos y móviles) tiene por objeto proteger la integridad del software y la información. En esta categoría tenemos a los siguientes controles:

- 10.4.1 (controles contra código malicioso): que describe los procedimientos para la implementación de controles para la detección, prevención y recuperación para protegerse contra código malicioso;
- 10.4.2 (controles contra códigos móviles): muestra las directrices para el uso de código móvil de forma segura.

En la categoría 10.5 (copias de seguridad de información), el objetivo es mantener la integridad y disponibilidad de la información a través del siguiente control:

- 10.5.1 se refiere a la necesidad de que copias de seguridad (*backup*) de la información y de los programas de software sean efectuadas y probadas regularmente.

La categoría 10.6 (gestión de seguridad de la red) tiene por objeto garantizar la protección de la información en las redes y la protección de la infraestructura de soporte. Esta categoría tiene dos controles:

- 10.6.1 (control de redes): se refiere a la necesidad de una adecuada gestión y control de las redes, incluida la información en tránsito;
- 10.6.2 (seguridad de los servicios de red): describe la necesidad de que los niveles de los servicios de red sean identificados e incluidos en los acuerdos de nivel de servicio.

En la categoría 10.7 (manipulación de medios) se describen los controles que deben ser aplicados para evitar la divulgación no autorizada, modificación, supresión o destrucción. Son los siguientes controles:

- 10.7.1 (gestión de medios removibles): describe la necesidad de controles para la gestión de medios removibles;
- 10.7.2 (eliminación de medios): muestra cómo se debe realizar la eliminación de los medios;
- 10.7.3 (procedimientos para el manejo de la información): presenta los controles que deben ser aplicados para el manejo y almacenamiento de la información, evitando la divulgación no autorizada;
- 10.7.4 (seguridad de la documentación del sistema): presenta el control de protección de la documentación del sistema.

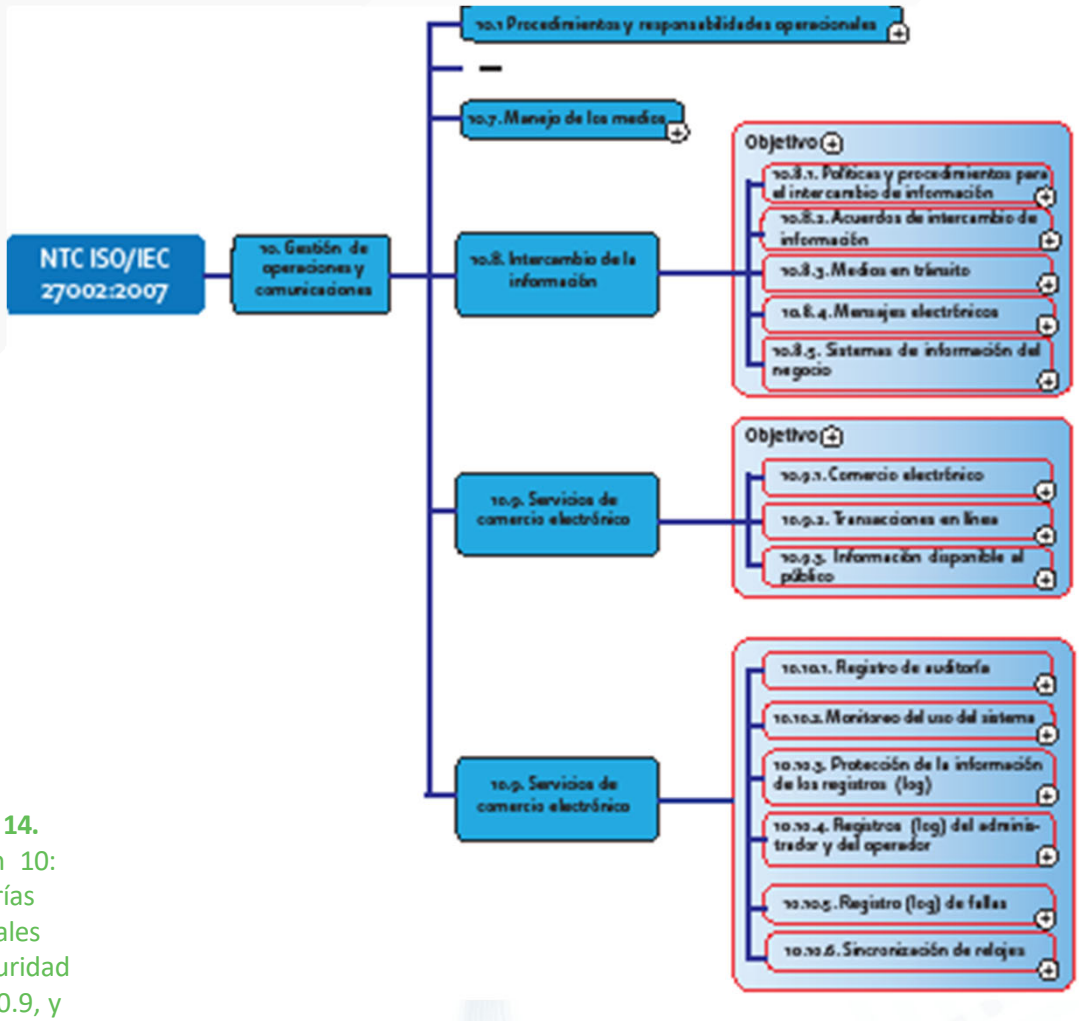


Figura 14. Sección 10: categorías principales de seguridad 10.8, 10.9, y 10.10 con sus controles.

La categoría 10.8 (intercambio de información) tiene como objetivo mantener la seguridad en el intercambio de la información interna y con entidades externas. Posee los siguientes controles:

- 10.8.1 (políticas y procedimientos para el intercambio de información): es conveniente que sean establecidas políticas y procedimientos para proteger el intercambio de información;
- 10.8.2 (acuerdos de intercambio de información): se deben establecer acuerdos para el intercambio de información;
- 10.8.3 (medios en tránsito): es recomendable que el transporte de los medios se haga bajo protección contra el uso indebido o el acceso no autorizado de esos dichos medios;

- 10.8.4 (mensajes electrónicos): es conveniente que los mensajes estén protegidos adecuadamente;
- 10.8.5 (sistema de información del negocio): se recomienda que las políticas y procedimientos estén diseñados para proteger la información en las interconexiones del sistema.

En la categoría 10.9 (servicios de comercio electrónico), el objetivo es garantizar la seguridad durante el uso de los servicios de comercio electrónico y su uso seguro. En esta categoría se encuentran los controles:

- 10.9.1 (comercio electrónico): se refiere a la protección de la información involucrada en el comercio electrónico contra las actividades fraudulentas;
- 10.9.2 (transacciones en línea): conviene realizar la protección de información para prevenir la transmisión incompleta, entre otros;
- 10.9.3 (información disponible al público): es recomendable asegurar la integridad de la información proporcionada en los sistemas públicos.

La categoría 10.10 (monitoreo) tiene como objetivo detectar las actividades no autorizadas de procesamiento de información. Los controles son:

- 10.10.1 (registros de auditoría): es importante que todos los *log* de auditoría de eventos de seguridad se generen y se conserven durante un período de tiempo acordado;
- 10.10.2 (monitoreo del uso del sistema): se deben establecer procedimientos para supervisar el uso de los recursos de procesamiento de la información;
- 10.10.3 (protección de la información de los registros (*log*)): los logs deben estar protegidos contra cambios no autorizados y problemas operacionales;
- 10.10.4 (registros (*log*) de administrador y operador): se recomienda registrar las actividades de los administradores y operadores del sistema;
- 10.10.5 (registros (*logs*) de las fallas): es conveniente que las fallas sean registradas y analizadas;
- 10.10.6 (sincronización de relojes): todos los sistemas relevantes deben tener sus relojes sincronizados.

Ejercicio de refuerzo - sección 10: gestión de operaciones y comunicaciones

Utilizando la norma, explique los controles

- 10.1.3
- 10.2.2
- 10.4.1
- 10.5.1
- 10.6.2
- 10.7.1
- 10.10.2

2.9 Sección 11: control de acceso

En la sección 11 (control de acceso) se encuentran las categorías que abordan los controles necesarios a los controles de acceso lógico. A diferencia de la sección 9 (seguridad física y del ambiente), en la sección 11 se abordarán aspectos relacionados con los privilegios de acceso, contraseñas, acceso a la red, entre otros. En esta sección hay siete principales categorías de seguridad.

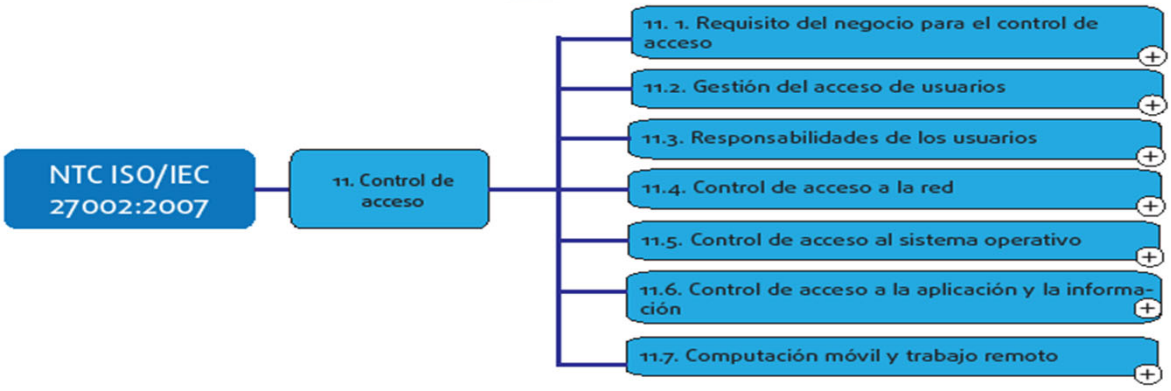


Figura 15. Sección 11 y sus siete categorías principales de seguridad

En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 11.1 (requisitos de negocio para el control de acceso), categoría 11.2 (gestión de acceso de usuario) y categoría 11.3 (responsabilidades de los usuarios).

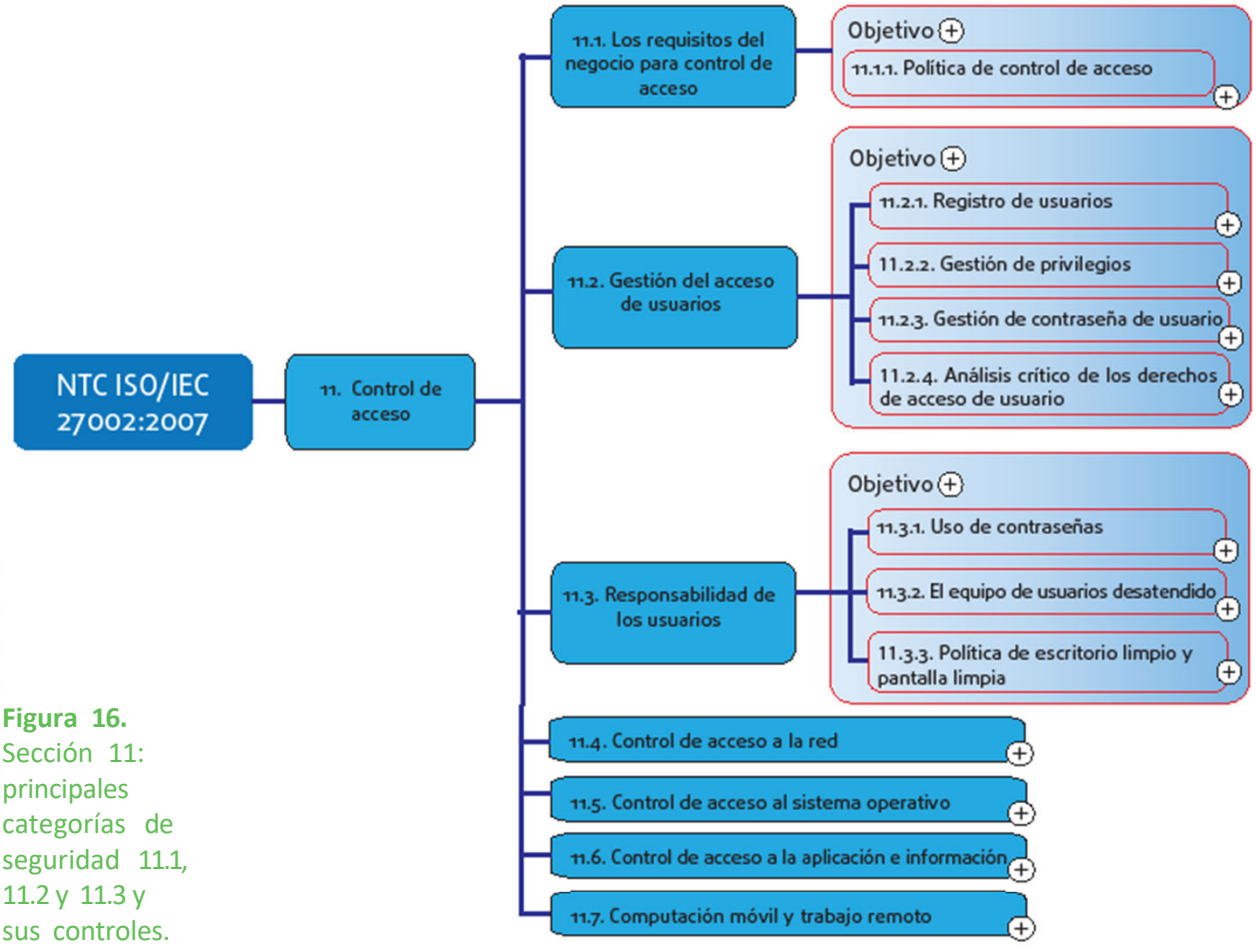


Figura 16. Sección 11: principales categorías de seguridad 11.1, 11.2 y 11.3 y sus controles.

En la categoría 11.1 (requisitos de negocio para el control de acceso) el objetivo es controlar el acceso a la información. El control es:

- 11.1.1 (política de control de acceso): debe haber una política de control de acceso establecida y analizada críticamente.

La categoría 11.2 (gestión de acceso de usuario): tiene como objetivo garantizar el acceso a los usuarios autorizados y evitar el acceso no autorizado. Los controles son:

- 11.2.1 (registro de usuario): describe la conveniencia de la existencia de un procedimiento formal de registro y cancelación de usuarios;
- 11.2.2 (gestión de privilegios): muestra la necesidad de que la concesión y uso de privilegios deben ser restringidos y controlados;
- 11.2.3 (gestión de contraseña): tiene la ventaja de que la concesión de las contraseñas sea controlada;
- 11.2.4 (análisis crítico de los derechos de acceso de usuario): presenta la conveniencia de que el administrador realice análisis críticos periódicos sobre los derechos de acceso de los usuarios.

La categoría 11.3 (responsabilidades de los usuarios) tiene por objeto prevenir el acceso no autorizado y evitar la afectación o el robo de los recursos. Contamos con los controles:

- 11.3.1 (uso de contraseñas): aborda la necesidad de los usuarios a seguir las mejores prácticas en el uso y la selección de las contraseñas;
- 11.3.2 (equipo del usuario desatendido): muestra la importancia de que los equipos desatendidos tengan la protección adecuada;
- 11.3.3 (política de escritorio limpio y pantalla limpia): muestra la conveniencia de adoptar una política de mesa limpia de papeles y de medios, y también de pantalla limpia.

En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 11.4 (control de acceso a redes) y categoría 11.5 (control de acceso al sistema operativo).



Figura 17. Sección 11: categorías principales de seguridad 11.4 y 11.5 con sus controles

La categoría 11.4 (control de acceso a redes) tiene por objeto prevenir el acceso no autorizado a los servicios de red. Tiene los siguientes controles:

- 11.4.1 (política de uso de los servicios de red): presenta la conveniencia de que los usuarios reciban acceso sólo a los servicios que hayan sido autorizados a usar;
- 11.4.2 (autenticación de usuarios para conexiones externas): recomienda que se usen métodos adecuados para controlar el acceso de usuarios remotos;

- 11.4.3 (identificación de los equipos en las redes): recomienda la conveniencia de permitir la identificación automática de los equipos;
- 11.4.4 (protección y configuración de puertos de diagnóstico remoto): recomienda que se controle el acceso físico y lógico a los puertos de diagnóstico y configuración;
- 11.4.5 (separación en las redes): recomienda que los usuarios y los sistemas sean separados en las redes;
- 11.4.6 (control de conexión de red): recomienda que la capacidad de los usuarios para conectarse a la red esté restringida,
- 11.4.7 (control de enrutamiento de la red): presenta la recomendación de que se implemente un control de enrutamiento de red para que las conexiones de red y los flujos de información no violen la política de control de acceso.

La categoría 11.5 (control de acceso al sistema operativo) tiene por objeto prevenir el acceso no autorizado a los sistemas operativos. Los controles son:

- 11.5.1 [Los procedimientos seguros para la entrada al sistema (*log-on*)]: muestra la conveniencia de que el acceso sea controlado por un procedimiento seguro para la entrada en el sistema;
- 11.5.2 (identificación y autenticación de usuarios): presenta la conveniencia de que todos los usuarios tengan un identificador único, con una técnica adecuada para la validación de la identidad del usuario;
- 11.5.3 (sistema de gestión de contraseñas): recomienda que los sistemas para la gestión de las contraseñas sean interactivos;
- 11.5.4 (uso de las utilidades del sistema): recomienda que el uso de las utilidades del sistema sea restringido y controlado;
- 11.5.5 (tiempo de inactividad de la sesión): muestra la necesidad de suspender las sesiones inactivas;
- 11.5.6 (limitación del tiempo de conexión): presenta la posibilidad de realizar restricciones en los tiempos de conexión.

En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 11.6 (control de acceso a las aplicaciones y la información) y categoría 11.7 (computación móvil y trabajo remoto).

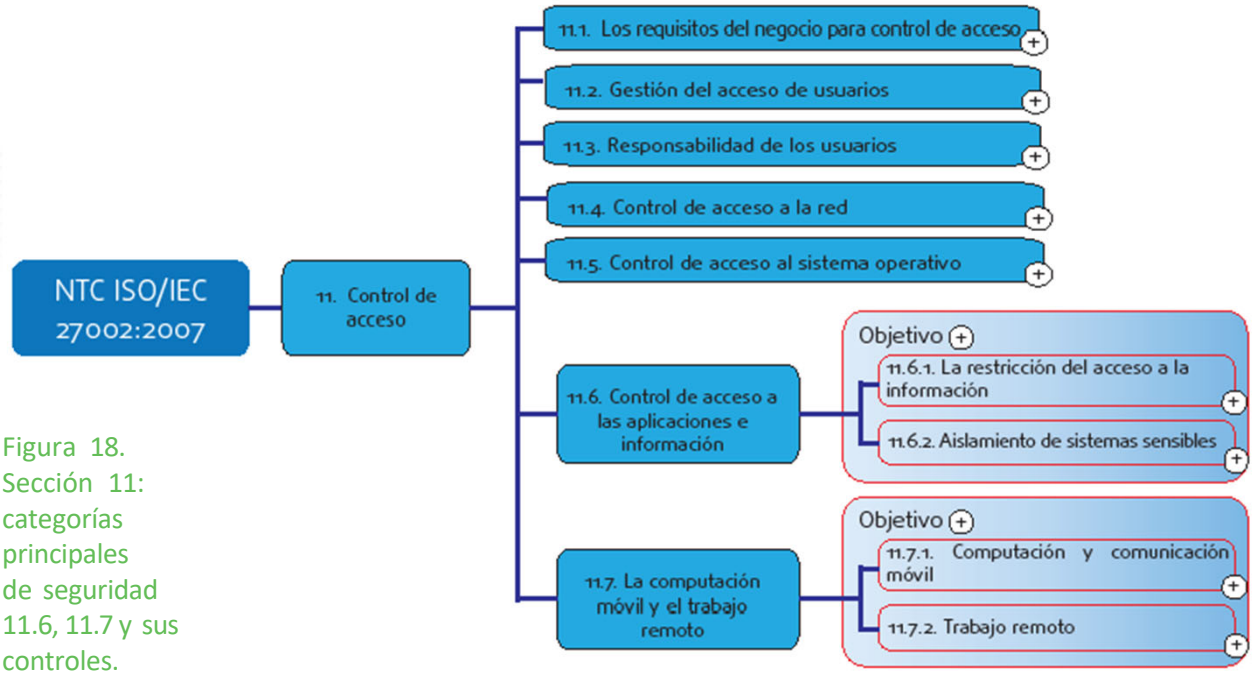


Figura 18. Sección 11: categorías principales de seguridad 11.6, 11.7 y sus controles.

En la categoría 11.6 (control de acceso a las aplicaciones y a la información), el objetivo es prevenir el acceso no autorizado a la información contenida en los sistemas de aplicación. Los controles son:

- 11.6.1 (restricción de acceso a la información): establece que el acceso a la información y las funciones de los sistemas de aplicación de los usuarios y personal de soporte sean restringidos;
- 11.6.2 (aislamiento de sistemas sensibles): recomienda que los sistemas sensibles tengan un ambiente informático aislado.

La categoría 11.7 (computación móvil y trabajo remoto) tiene como objetivo garantizar la seguridad de la información cuando se utilizan la computación móvil y el trabajo remoto. Los controles son:

- 11.7.1 (computación y comunicación móvil): recomienda la adopción de políticas y medidas contra los riesgos debidos al uso de los recursos informáticos y de comunicaciones móviles;
- 11.7.2 (trabajo remoto): presenta las ventajas de que las políticas, planes y procedimientos sean elaborados e implementados para el trabajo remoto.

Ejercicio de refuerzo - sección 11: control de acceso

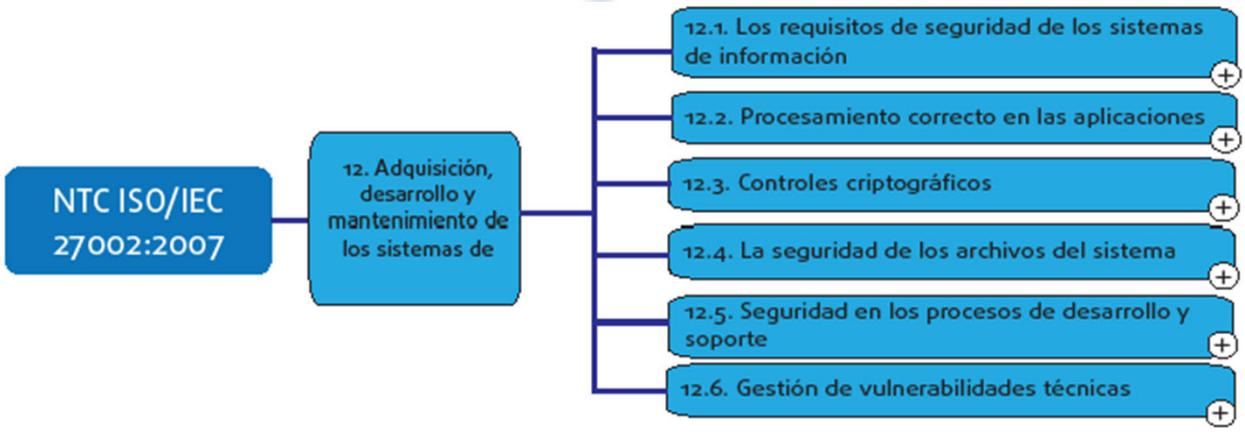
Utilizando la norma, explique los controles

- 11.1.1
- 11.2.2
- 11.3.3
- 11.5.5
- 11.6.2

2.10 Sección 12: adquisición, desarrollo y mantenimiento de sistemas de información.

En la sección 12 (adquisición, desarrollo y mantenimiento de sistemas de información) están los controles sobre la adquisición, desarrollo y mantenimiento de las actividades de software. El objetivo de esta sección es desarrollar la seguridad de la información en las aplicaciones de la organización. Esta sección tiene seis categorías principales de seguridad.

Figura 19. Sección 12 y sus seis categorías principales de seguridad



En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 12.1 (requisitos de seguridad de sistemas de información), categoría 12.2 (procesamiento correcto en las aplicaciones) y categoría 12.3 (controles criptográficos).

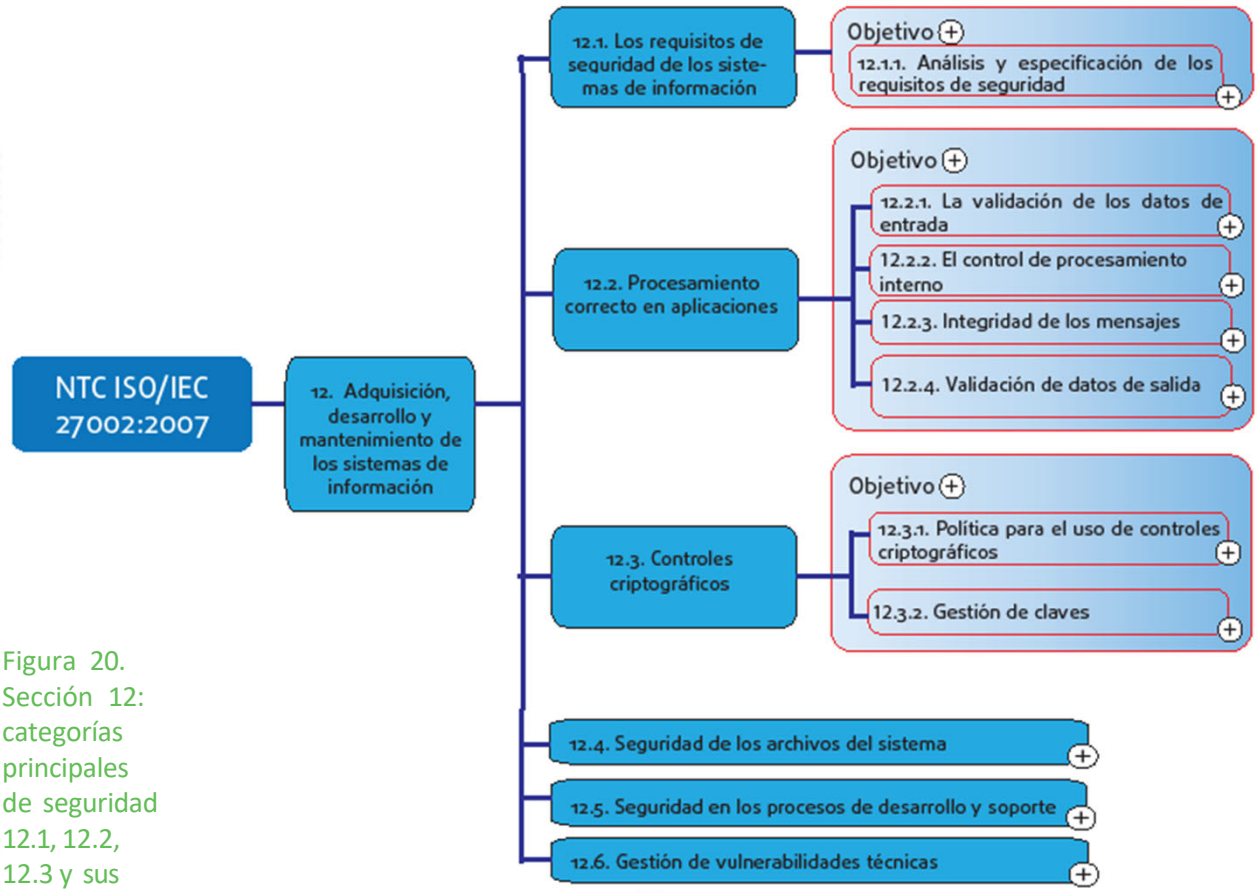


Figura 20. Sección 12: categorías principales de seguridad 12.1, 12.2, 12.3 y sus controles.

La categoría 12.1 (requisitos de seguridad de sistemas de información) tiene por objeto garantizar que la seguridad es una parte integrante de los sistemas de información. Tiene el siguiente control:

- 12.1.1 (análisis y especificación de requisitos de seguridad): define los controles de seguridad en las especificaciones de requisitos para los nuevos sistemas.

En la categoría 12.2 (procesamiento correcto en las aplicaciones) el objetivo es prevenir la ocurrencia de errores, pérdida, modificación no autorizada o mal uso de la información en las aplicaciones. Los controles son:

- 12.2.1 (validación de datos de entrada): establece que los datos de entrada a las aplicaciones sean validados para asegurar que son correctos y adecuados;
- 12.2.2 (control de procesamiento interno): se recomienda comprobar que la validación se incorpora en las aplicaciones para detectar corrupción de datos;

- 12.2.3 (integridad de mensajes): establece que se implementen requisitos para garantizar la autenticidad y proteger la integridad;
- 12.2.4 (Validación de datos de salida): se recomienda que los datos de salida sean validados para garantizar que el procesamiento es correcto.

La categoría 12.3 (controles criptográficos) tiene por objeto proteger la confidencialidad, autenticidad o integridad de la información por medios criptográficos. Los controles son:

- 12.3.1 (política sobre el uso de controles criptográficos): en ella se recomienda que se desarrolle e implemente una política para el uso de controles criptográficos.
- 12.3.2 (gestión de claves): presenta las ventajas de que un proceso de gestión de claves sea implantado para apoyar el uso de técnicas criptográficas

En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 12.4 (seguridad de los archivos del sistema), categoría 12.5 (seguridad en los procesos de desarrollo y soporte) y categoría 12.6 (gestión de las vulnerabilidades técnicas).

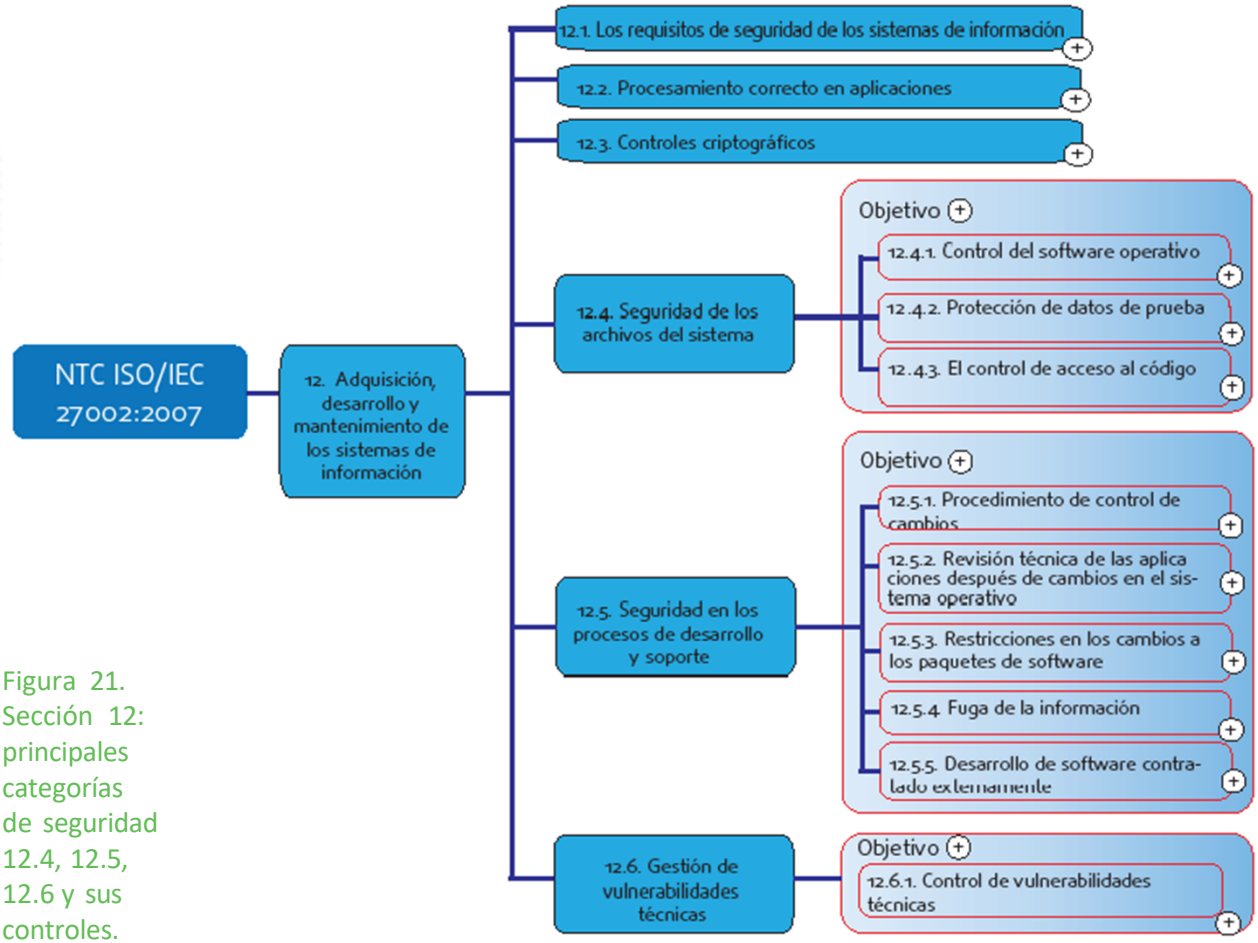


Figura 21. Sección 12: principales categorías de seguridad 12.4, 12.5, 12.6 y sus controles.

La categoría 12.4 (seguridad de los archivos del sistema) tiene por objeto garantizar la seguridad de los archivos del sistema. Los controles son:

- 12.4.1 (control de software operativo): se deben implementar procedimientos para el control de la instalación de software en los sistemas operativos;
- 12.4.2 (protección de datos para la prueba del sistema): presenta la recomendación de que los datos de prueba sean seleccionados con cuidado, protegidos y controlados,
- 12.4.3 (controlar el acceso al código fuente del programa): especifica que el acceso al código fuente sea restringido.

La categoría 12.5 (seguridad en los procesos de desarrollo y soporte) tiene como objetivo mantener la seguridad de los sistemas de información y aplicaciones. Posee los controles:

- 12.5.1 (procedimientos de control de cambios): es conveniente que la implementación de cambios sea controlada con el uso de procedimientos formales de control de cambios;

- 12.5.2 (revisión técnica de las aplicaciones después de los cambios del sistema operativo): considera conveniente que las aplicaciones críticas sean analizadas y probadas cuando se cambian los sistemas operativos;
- 12.5.3 (restricciones a los cambios en los paquetes de software): presenta la recomendación de que todos los cambios sean estrictamente controlados;
- 12.5.4 (fuga de información): resalta la necesidad de evitar toda oportunidad de fuga de información;
- 12.5.5 (desarrollo de software contratado externamente): la organización debe supervisar y monitorear el desarrollo de software contratado externamente.

En la categoría 12.6 (gestión de las vulnerabilidades técnicas) el objetivo es reducir los riesgos derivados de la explotación de las vulnerabilidades técnicas conocidas. El control es:

- 12.6.1 (control de las vulnerabilidades técnicas): es conveniente obtener información sobre las vulnerabilidades técnicas, los riesgos deben ser evaluados y se deben tomar los cuidados necesarios.

Ejercicio de refuerzo - sección 12: adquisición, desarrollo y mantenimiento de sistemas de información.

Utilizando la norma, explique los controles

- 12.1.1
- 12.2.2
- 12.3.1
- 12.5.4
- 12.6.1

2.11 Sección 13: gestión de incidentes de seguridad de la información.

Sección 13 (gestión de incidentes de seguridad de la información) se refiere al reporte de eventos de seguridad, las responsabilidades y el proceso de recolección de evidencia. Tiene dos categorías de seguridad principales.

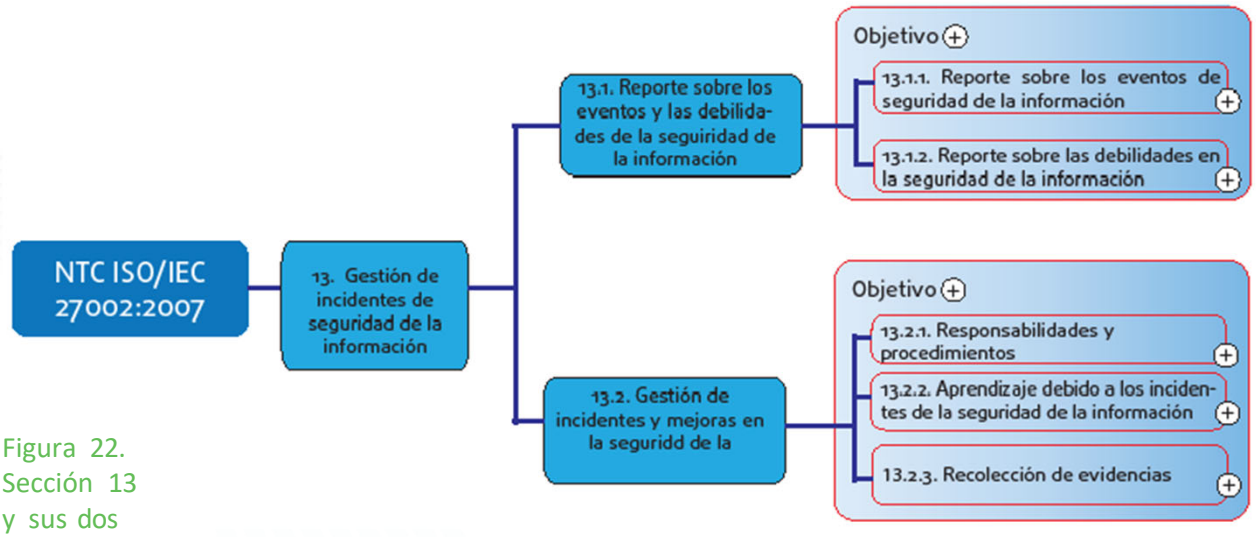


Figura 22. Sección 13 y sus dos principales categorías de seguridad y los controles

La categoría 13.1 (reportes sobre los eventos y las debilidades de la seguridad de la información) tiene como objetivo asegurar que los eventos y las debilidades de la seguridad sean comunicados, permitiendo tomar medidas correctivas en tiempo real. Tiene los controles:

- 13.1.1 (reporte sobre los eventos de seguridad de la información): define que los eventos de seguridad sean informados a través de los canales apropiados tan pronto como sea posible,
- 13.1.2 (reporte sobre las debilidades en la seguridad de la información): se recomienda que todos los recursos humanos sean instruidos para registrar y reportar cualquier observación o sospecha de deficiencia de los sistemas y servicios.

La categoría 13.2 (gestión de incidentes y mejoras en la seguridad de la información) tiene por objeto garantizar que un enfoque coherente y eficaz sea aplicado a la gestión de incidentes de seguridad de la información. Los controles son:

- 13.2.1 (responsabilidades y procedimientos): presenta la conveniencia de que las responsabilidades y los procedimientos se establezcan para garantizar una respuesta rápida;
- 13.2.2 (aprendizaje debido a los incidentes de seguridad de la información): recomienda que se establezcan mecanismos para monitorear y cuantificar los tipos y costos de los incidentes;

» 13.2.3 (recolección de evidencia): presenta la necesidad de recolectar la evidencia, almacenarla y se presentarla de conformidad con la legislación pertinente.

Ejercicio de refuerzo - sección 13: gestión de incidentes de seguridad de la información.

Utilizando la norma, explique los controles

» 13.1.1
» 13.1.2
» 13.2

2.12 Sección 14: gestión de la continuidad del negocio.

La sección 14 (gestión de la continuidad del negocio) se encarga de todos los aspectos de la continuidad en el caso de un desastre. Esta sección tiene una sola categoría principal de seguridad.

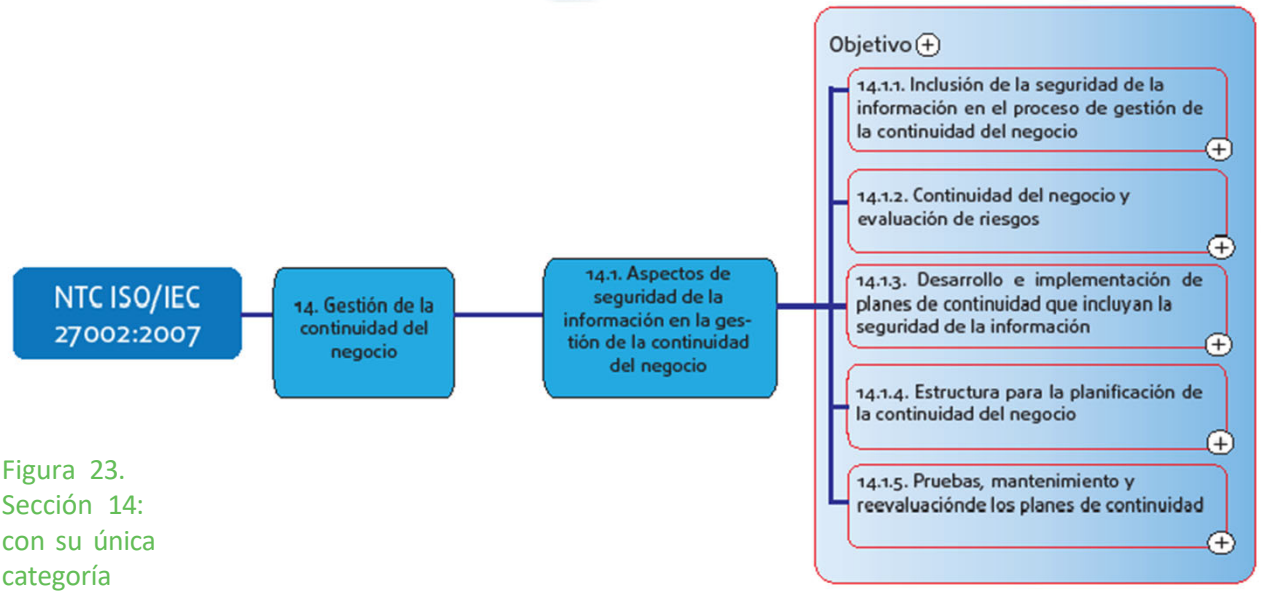


Figura 23. Sección 14: con su única categoría principal de la seguridad y sus controles

La categoría 14.1 (aspectos de seguridad de la información en la gestión de la continuidad del negocio) tiene como objetivo no permitir la interrupción de las actividades del negocio y proteger los procesos críticos contra los efectos de fallas o desastres significativos, y asegurar su reactivación de manera oportuna, si es el caso. Los controles son:

- 14.1.1 (inclusión de la seguridad de la información en el proceso de gestión de la continuidad del negocio): es conveniente que sea desarrollado y mantenido un proceso de gestión de continuidad de negocio de la organización, contemplando los requisitos de seguridad;
- 14.1.2 (continuidad del negocio y evaluación de riesgos): se deben identificar los eventos que pueden causar la interrupción del negocio;
- 14.1.3 (desarrollo e implementación de planes de continuidad que incluyan la seguridad de la información): es importante que los planes se elaboren y se implementen;
- 14.1.4 (estructura para la planificación para la continuidad del negocio): presenta la necesidad de una estructura básica y consistente de los planes de continuidad del negocio;
- 14.1.5 (pruebas, mantenimiento y reevaluación de los planes de continuidad del negocio): los planes deben ser probados y actualizados con regularidad.

Ejercicio de refuerzo - sección 14: gestión de la continuidad del negocio

Utilizando la norma, explique los controles

- 14.1.2
- 14.1.3

2.13 Sección 15: cumplimiento

La sección 15 (cumplimiento) establece que los requisitos de seguridad de la información estén de acuerdo con cualquier Ley (legalidad), como reglamentos, estatutos u obligaciones contractuales. Esta sección tiene tres categorías principales de seguridad.

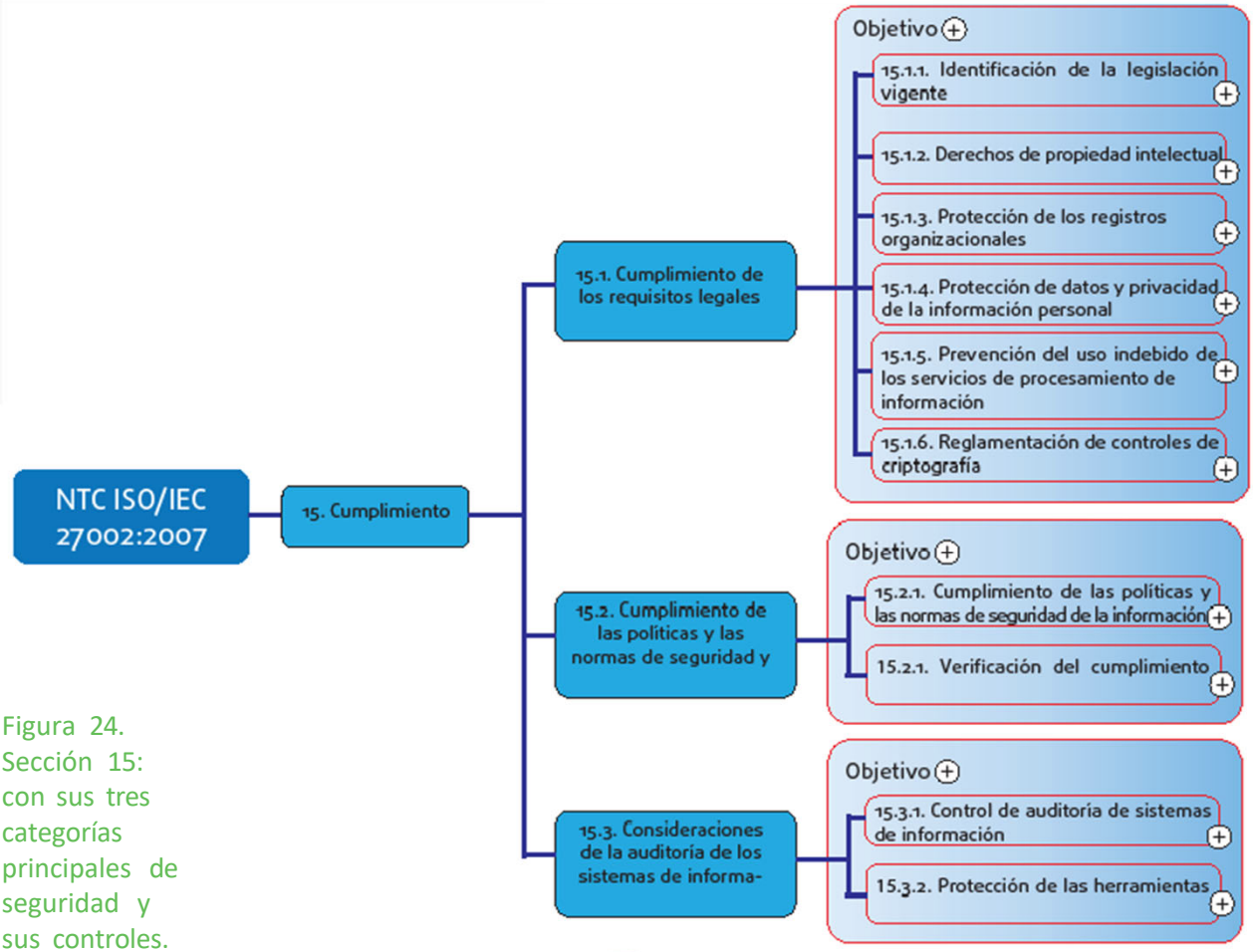


Figura 24. Sección 15: con sus tres categorías principales de seguridad y sus controles.

La categoría 15.1 (cumplimiento de los requisitos legales) tiene como objetivo prevenir la violación de cualquier Ley penal o civil, estatutos, reglamentaciones u obligaciones contractuales y cualquier otro requisito de seguridad de la información. Cuenta con los siguientes controles:

- 15.1.1 (identificación de la legislación vigente): considera conveniente que todos los requisitos legales y contractuales se definan explícitamente, y sean documentados y mantenidos;
- 15.1.2 (derechos de propiedad intelectual): recomienda que se implementen procedimientos para garantizar el cumplimiento de los derechos de propiedad intelectual;
- 15.1.3 (protección de los registros organizacionales): recomienda que los registros sean protegidos contra pérdida, destrucción y falsificación;
- 15.1.4 (protección de datos y privacidad de la información personal): indica que la privacidad y la protección de datos sean garantizadas;
- 15.1.5 (prevención del uso indebido de los servicios de procesa-

miento de información): se recomienda que los usuarios sean disuadidos de usar los servicios informáticos para propósitos no autorizados,
- 15.1.6 (Reglamento de controles criptográficos): recomienda que controles criptográficos se utilicen de acuerdo con la legislación vigente.

La categoría 15.2 (cumplimiento de las normas y políticas para la seguridad de la información y cumplimiento técnico) tiene por objeto garantizar la conformidad de los sistemas con las políticas y normas organizacionales de seguridad de la información. Sus controles son:

- 15.2.1 (cumplimiento con las políticas y normas de seguridad de la información): recomienda que los gestores garanticen que todos los procedimientos de seguridad de la información dentro de su área están funcionando correctamente,
- 15.2.2 (verificación del cumplimiento técnico): considera conveniente que los sistemas de información sean verificados periódicamente para determinar el cumplimiento con las normas de implementación de la seguridad.

En la categoría 15.3 (consideraciones de la auditoría de los sistemas de información), el objetivo es maximizar la eficacia y minimizar la interferencia en el proceso de auditoría de los sistemas de información. Los controles son:

- 15.3.1 (controles de auditoría de sistemas de información): los requisitos y las actividades de auditoría deben ser cuidadosamente planificados.
- 15.3.2 (protección de las herramientas de auditoría de sistemas de información): se debe proteger el acceso a las herramientas de auditoría de los sistemas de información.

Ejercicio de refuerzo - sección 15: cumplimiento

Utilizando la norma, explique los controles

- 15.1.1
- 15.1.2
- 15.1.4
- 15.2.1
- 15.3.1